Active Reconnaissance and Network Scanning

Mapping the attack surface before attackers do.

```
$ sudo nmap -sS -sV 192.168.56.20
```

Learning objectives

1. Explain active recon and its legal limits
2. Find live hosts on an authorized network
3. Scan open TCP and UDP ports
4. Detect services and versions
5. Do basic service enumeration
6. Read Nmap output and port states
7. Save evidence, write a findings report
8. Exposed service is not a confirmed vulnerability

Passive vs active reconnaissance

	Passive	Active
How	No direct contact with target	Sends packets or probes to target
Examples	Google, WHOIS, DNS history, certificate logs	Nmap, DNS queries, banner checks
Detection	Low chance	Logged by firewall, IDS/IPS, servers
Risk	Usually low	May trigger alerts or hit fragile systems
Best for	Early attack-surface research	Confirming live assets and exposed services

OSINT: a host may exist. Active recon: it is reachable today, with these ports open.

Rules of engagement: before you scan

1. Explicit written authorization
2. Confirm in-scope IPs, domains, apps, cloud assets
3. Confirm dates and testing window
4. Prohibited: prod databases, critical, medical/OT, third-party
5. Agree scan speed, intensity, tools
6. Name a contact if something breaks
7. Are exploits, logins, password attacks, vuln scans allowed?
8. Record your source IP for defenders

Not listed in scope = out of scope. Scanning without permission can be unlawful.

Lab setup: safe practice

Use one of these

- Your own Kali Linux + local VM
- Metasploitable, OWASP BWA, DVWA in an isolated network
- TryHackMe, Hack The Box Academy
- University lab range
- Docker vulnerable-app lab

```
Kali attacker VM:  192.168.56.10
Target vulnerable: 192.168.56.20
Network mode: Host-only / Internal
Internet exposure: Disabled
```

Never

- Point commands at random public IPs
- Scan outside your lab

Networking basics: IPs and ports

IP address

- Identifies a device on a network
- e.g. 192.168.1.10

Private IPv4 ranges

- 10.0.0.0/8
- 172.16.0.0/12
- 192.168.0.0/16
- Not routed on the internet

Port	Service	Purpose
21	FTP	File transfer
22	SSH	Secure remote shell
23	Telnet	Unencrypted remote shell
25	SMTP	Sending email
53	DNS	Name lookup (TCP/UDP)
80	HTTP	Web
110	POP3	Email download
135	MS RPC	Windows remote calls
139	NetBIOS	Old Windows sharing

Port	Service	Purpose
143	IMAP	Email access
161	SNMP	Device monitoring (UDP)
389	LDAP	Directory / users
443	HTTPS	Encrypted web
445	SMB	File shares
3306	MySQL	Database
3389	RDP	Windows remote desktop
5432	PostgreSQL	Database
6379	Redis	In-memory store
8080	HTTP-alt	Alternative web

Open port = something is listening. Not automatically vulnerable.

TCP and UDP

TCP: connection-oriented

- Clear responses, easier to scan
- HTTP/S, SSH, SMB, FTP, RDP, MySQL
- Handshake below

UDP: connectionless

- No handshake
- Faster, harder to scan reliably
- Some services stay silent until a valid request
- DNS, NTP, SNMP, DHCP, TFTP, IPsec/IKE

```
Client -> SYN     -> Server
Client <- SYN/ACK <- Server
Client -> ACK     -> Server
```

SYN = request to connect. SYN/ACK = accepted. ACK = confirmed.

Port states

State	Meaning
open	Application is listening
closed	Host reachable, nothing listening
filtered	Firewall/ACL blocked probe: state unknown
unfiltered	Reachable, but open or closed unknown
open|filtered	Cannot tell open from filtered
closed|filtered	Cannot tell closed from filtered

filtered does not mean open. Closed ports usually mean unused services are not exposed.

Introducing Nmap

Network Mapper

- Free, open source
- Discovers hosts and open ports
- Detects services, versions, OS
- Runs optional scripts

Command	Meaning
`nmap --version`	Show installed version
`sudo apt install nmap`	Install on Kali / Debian
`nmap [options] [target]`	Basic syntax

Target form	Meaning
`nmap 192.168.56.20`	One host
`nmap 192.168.56.0/24`	Whole /24 subnet (256 addresses)
`nmap scanme.nmap.org`	Hostname (Nmap test server, follow its rules)
`nmap -iL targets.txt`	Read targets from a file

Host discovery

Goal: find which devices are alive before deeper scans.

Command	What it means
`sudo nmap -sn 192.168.56.0/24`	-sn: discovery only, no port scan. Ping sweep
`sudo nmap -sn -PR 192.168.56.0/24`	-PR: ARP requests. Local Layer 2 network only
`sudo nmap -sn -PS22,80,443 192.168.56.0/24`	-PS: TCP SYN probes to ports 22, 80, 443. Works when ICMP is blocked
`sudo nmap -Pn 192.168.56.20`	-Pn: treat host as up, skip discovery

A host that blocks ping can still run web, SSH or SMB. Avoid -Pn on big networks: slow and noisy.

Basic TCP port scanning

Command	What it means
`sudo nmap 192.168.56.20`	Default: top 1,000 common TCP ports
`sudo nmap -sS 192.168.56.20`	-sS: SYN (half-open) scan. Needs root. Fast
`nmap -sT 192.168.56.20`	-sT: full connection. No root needed. More visible in logs
`sudo nmap -p 1-1000 192.168.56.20`	-p 1-1000: ports 1 to 1000
`sudo nmap -p 21,22,80,443,445,3389 192.168.56.20`	-p list: only these ports
`sudo nmap -p- 192.168.56.20`	-p-: all 65,535 TCP ports

Start low-impact, review, then focus on the exposed services that matter.

Service and version detection

Command	What it means
`sudo nmap -sV 192.168.56.20`	-sV: probe open ports to find service and version
`sudo nmap -sS -sV -p 21,22,80,443 192.168.56.20`	SYN scan + version detection on chosen ports

```
PORT    STATE SERVICE VERSION
21/tcp  open  ftp     vsftpd 2.3.4
22/tcp  open  ssh     OpenSSH 8.2p1
80/tcp  open  http    Apache 2.4.41
```

Services run on odd ports: 8080 web, 2222 SSH, 9000 dashboard. A version is a lead, not proof of a flaw.

Columns

- PORT: number/protocol
- STATE: open, closed, filtered
- SERVICE: Nmap protocol guess
- VERSION: product + version

OS detection and aggressive mode

Command	What it means
`sudo nmap -O 192.168.56.20`	-O: guess the operating system from network behavior
`sudo nmap --traceroute 192.168.56.20`	Show the network hops to the target
`sudo nmap -A 192.168.56.20`	-A: OS + version + default scripts + traceroute

Why -A is used with care

- Many probes: slower and noisy
- More alerts in IDS/IPS
- Can be unsuitable for production
- Use on purpose, not by default

UDP scanning

Command	What it means
`sudo nmap -sU --top-ports 20 192.168.56.20`	-sU: UDP scan. --top-ports 20: 20 most common UDP ports
`sudo nmap -sU -p 53,69,123,161,500 192.168.56.20`	UDP ports: 53 DNS, 69 TFTP, 123 NTP, 161 SNMP, 500 IKE/IPsec

Key UDP services

- 53 DNS: name lookup
- 69 TFTP: simple file transfer
- 123 NTP: time sync
- 161 SNMP: device monitoring
- 500 IKE: IPsec VPN setup
- 514 Syslog: log forwarding

Remember

- Slower than TCP
- No reply = open|filtered
- Confirm with protocol-specific safe queries
- Avoid high rates on real networks
- TCP-only scans leave blind spots

Saving scan results

Command	What it means
`sudo nmap -sS -sV -oN basic_scan.txt 192.168.56.20`	-oN: normal text. Easy to read, attach to report
`sudo nmap -sS -sV -oX basic_scan.xml 192.168.56.20`	-oX: XML. Import into reporting/analysis tools
`sudo nmap -sS -sV -oG basic_scan.gnmap 192.168.56.20`	-oG: grepable. Quick filtering, shell scripts
`sudo nmap -sS -sV -oA recon_scan 192.168.56.20`	-oA: all formats, one base name. Best default

Why keep raw output

- Evidence, reporting, comparing scans
- Team sharing, tool parsing, re-testing after fixes

Nmap Scripting Engine (NSE)

Command	What it means
`sudo nmap -sV -sC 192.168.56.20`	-sC: run the default script set
`nmap --script http-title -p 80,443 192.168.56.20`	Read web page title
`nmap --script http-methods -p 80,443 192.168.56.20`	List allowed HTTP methods (GET, PUT…)
`sudo nmap --script smb-os-discovery -p 445 192.168.56.20`	Get OS and host name over SMB
`nmap --script ssl-cert -p 443 192.168.56.20`	Show TLS certificate details
`nmap --script ftp-anon -p 21 192.168.56.20`	Check for anonymous FTP login

Read a script's purpose first. "Safe" is not "zero impact".

Web service enumeration

Ports 80, 443, 8080, 8443: open in a browser first.

Command	What it means
`whatweb http://192.168.56.20`	Identify server, CMS, framework
`curl -I http://192.168.56.20`	-I: fetch response headers only
`curl -s http://192.168.56.20 | head`	-s: silent. head: first 10 lines of page
`nmap --script http-title,http-headers,http-methods -p 80,443 192.168.56.20`	Title, headers, methods via NSE

Look for

- Login portals, API docs, dev/staging pages, default pages
- Directory listings, backup and config files, versions
- Banners can be hidden or faked: confirm with two sources

DNS enumeration

DNS can reveal

- Domain controllers
- Mail servers
- Application servers
- Internal hostnames
- Dev environments
- Third-party / cloud records

Command	Meaning
`dig example.local`	Query default record
`dig @192.168.56.20 example.local`	@: ask this specific DNS server
`dig example.local A`	A: IPv4 address
`dig example.local MX`	MX: mail servers
`dig example.local TXT`	TXT: text records (SPF, etc.)
`dig example.local NS`	NS: name servers
`dig axfr @192.168.56.20 example.local`	axfr: zone transfer. Authorized only

Successful zone transfer = misconfiguration. Capture evidence, report it.

SMB enumeration

Ports 139/tcp and 445/tcp: Windows file sharing.

Command	What it means
`sudo nmap --script smb-os-discovery -p 445 192.168.56.20`	OS, host and domain name
`smbclient -L //192.168.56.20 -N`	-L: list shares. -N: no password
`enum4linux-ng -A 192.168.56.20`	-A: all checks: users, groups, shares, policy

Can reveal

- Host, domain, OS
- Shares, users, groups
- Anonymous access
- Password policy

Report

- Anonymous shares
- Sensitive files via guest
- Legacy SMB support
- Unneeded SMB exposure
- Missing SMB signing

SSH, FTP and remote access

SSH: port 22

- Old versions
- Weak crypto
- Exposed admin access
- Banner leaks

FTP: port 21

- Anonymous login
- Writable folders
- Sensitive files
- Unencrypted legacy use

RDP: port 3389

- Open to untrusted nets
- MFA, NLA
- Account lockout
- VPN / zero trust

Command	What it means
`sudo nmap -sV -p 22 192.168.56.20`	Version detection on SSH
`sudo nmap -sV -p 21 192.168.56.20 / --script ftp-anon`	Version, then anonymous check
`sudo nmap -sV -p 3389 192.168.56.20`	Version detection on RDP

Scan carefully: speed and impact

Command	What it means
`sudo nmap -T3 -sS -sV 192.168.56.20`	-T3: normal timing. Safer default
`sudo nmap -T4 -sS -sV 192.168.56.20`	-T4: faster. Lab use

Risks of fast scans

- Missed results
- Stress on fragile devices
- More logs and alerts

Extra caution

- OT, IoT, healthcare, legacy
- Production networks
- Follow rules-of-engagement rate limits
- Accuracy and safety over speed

Key takeaways

1. Active recon needs authorization
2. Open port = something listening, not a flaw
3. Version detection gives leads to validate
4. Save raw output as evidence
5. Document findings, impact, and fixes